

SOC L1 Analist Operasyonları: Uyarı Yönetimi, Raporlama ve Performans Metrikleri

Özet

Bu brifing, bir Güvenlik Operasyonları Merkezi (SOC) içindeki Seviye 1 (L1) analistlerinin temel sorumluluklarını, süreçlerini ve performans ölçütlerini özetlemektedir. L1 analistleri, SIEM ve EDR gibi güvenlik çözümleri tarafından üretilen uyarıları önceliklendirmekten, incelemekten ve yönetmekten sorumludur. Temel görevleri, milyonlarca ham log arasından şüpheli olayları tespit eden uyarıları analiz ederek gerçek tehditleri (True Positive) gürültüden (False Positive) ayırmaktır.

Etkili bir uyarı yönetim süreci; uyarıyı sahiplenme, durumunu "İnceleniyor" olarak değiştirme, teknik bilgi ve "Çalışma Kitapları" (Workbooks) gibi destekleyici dokümanları kullanarak ayrıntılı bir inceleme yapma ve son olarak uyarı hakkında bir karara varma adımlarını içerir. Bu süreç, "Beş N" (Kim, Ne, Nerede, Ne Zaman, Neden) kuralına dayanan ayrıntılı bir raporlama ile belgelenir. Derinlemesine analiz veya müdahale gerektiren gerçek pozitif uyarılar, Seviye 2 (L2) analistlerine yükseltilir.

SOC ekibinin verimliliği, Uyarı Sayısı, Yanlış Pozitif Oranı, Uyarı Yükseltme Oranı ve Tehdit Tespit Oranı gibi temel metriklerle ölçülür. Ayrıca, Hizmet Seviyesi Anlaşmaları (SLA) kapsamında tanımlanan Ortalama Tespit Süresi (MTTD) ve Ortalama Müdahale Süresi (MTTR) gibi zamana dayalı metrikler, tehditlere zamanında yanıt verilmesini sağlamak için kritik öneme sahiptir. L1 analistlerinin bu süreçlerdeki başarısı, büyük ölçüde Kimlik ve Varlık Envanterleri ile Çalışma Kitapları gibi destekleyici araçların etkin kullanımına bağlıdır.

1. Uyarı Yönetim Süreci

SOC analistlerinin temel görevi, güvenlik sistemleri tarafından üretilen uyarıları yönetmektir. Bu süreç, ham sistem olaylarının analistler için yönetilebilir ve eyleme geçirilebilir bildirimlere dönüştürülmesini içerir.

1.1. Olaylardan Uyarılara

Güvenlik izleme süreci bir **olay** ile başlar; bu bir kullanıcı girişi, bir işlemin başlatılması veya bir dosyanın indirilmesi olabilir. Bu olaylar, işletim sistemleri veya güvenlik duvarları gibi sistemler tarafından kaydedilir ve **sistem logları** olarak merkezi bir güvenlik çözümüne (SIEM veya EDR gibi) gönderilir. SOC ekipleri günde binlerce sistemden milyonlarca log

alabilir. Bir **uyarı**, belirli bir olayın veya olay dizisinin meydana gelmesi durumunda güvenlik çözümü tarafından oluşturulan bir bildirimdir. Uyarılar, analistleri milyonlarca ham logu manuel olarak incelemekten kurtararak yalnızca şüpheli ve anormal olayları vurgular, böylece analistler günde sadece onlarca uyarıyı inceler.

1.2. Uyarıların Yönetildiği Platformlar

L1 analistleri uyarıları çeşitli platformlarda alır ve yönetir. Bu platformlar, uyarıların toplanması, merkezileştirilmesi ve analiz edilmesi için farklı yetenekler sunar.

Çözüm	Tanım	Örnekler	Açıklama
SIEM	Güvenlik bilgilerini log, uyarı ve olaylar şeklinde merkezi bir platformda toplayan ve güvenlik analistlerinin gerçek zamanlı analiz yapmasını sağlayan Güvenlik Bilgi ve Olay Yönetimi sistemidir.	Splunk ES, Elastic	SIEM'ler, sağlam uyarı yönetimi yeteneklerine sahiptir ve çoğu SOC ekibi için mükemmel bir seçimdir.
EDR/NDR	Uç Nokta Tespiti ve Yanıtı (EDR), cihazları bir tehdit gösterebilecek etkinliklere karşı izleyen bir dizi araçtır.	MS Defender, CrowdStrike	EDR ve NDR kendi uyarı panolarını sunsa da, SIEM veya SOAR kullanmak tercih edilir.
SOAR	Güvenlik Orkestrasyonu, Otomasyonu ve Yanıtı (SOAR), kuruluşların olay yönetimi ve tehdit istihbaratı gibi güvenlik operasyonlarını otomatikleştirmesine yardımcı olan bir çözümdür.	Splunk SOAR, Cortex SOAR	Daha büyük SOC ekipleri, birden fazla çözümden gelen uyarıları toplamak ve merkezileştirmek için SOAR kullanabilir.
ITSM	BT Hizmet Yönetimi (ITSM) araçları, olay ve değişiklik yönetimi süreçlerini izlemeye ve otomatikleştirmeye yardımcı olur. SOC ekipleri, güvenlik olaylarını yönetmek için Jira veya ServiceNow gibi ITSM araçlarını kullanabilir.	Jira, TheHive	Bazı ekipler, özel bir bilet yönetimi (ITSM) çözümüne sahip olabilir.

1.3. Uyarı Önceliklendirme (Triage) Adımları

Uyarı önceliklendirme, bir uyarının meşruiyetini ve potansiyel etkisini belirlemek için izlenen yapılandırılmış bir süreçtir.

- **Başlangıç Eylemleri:** Bu adımlar, bir analistin uyarıyı sahiplenmesini ve diğer analistlerle çakışmayı önlemesini sağlar. Süreç, uyarıyı kendine atamak, durumunu **"İnceleniyor" (In Progress)** olarak değiştirmek ve uyarının adı, açıklaması ve temel göstergeleri gibi ayrıntıları gözden geçirmekle başlar.
- **İnceleme:** Bu en karmaşık adımdır ve analistin teknik bilgi ve deneyimini kullanarak etkinliği anlamasını ve SIEM veya EDR loglarında meşruiyetini analiz etmesini gerektirir. Bu süreçte analistlere yardımcı olmak için bazı ekipler, belirli uyarı kategorilerinin nasıl inceleneceğine dair talimatlar içeren **Çalışma Kitapları (Workbooks)** geliştirir. Çalışma Kitapları mevcut değilse, aşağıdaki öneriler takip edilebilir:
 1. Etkilenen kullanıcı, ana bilgisayar adı, bulut veya ağ gibi tehdit altındaki varlığı anlamak.
 2. Şüpheli bir giriş, kötü amaçlı yazılım veya kimlik avı gibi uyarıda açıklanan eylemi not etmek.
 3. Uyarıdan hemen önce veya sonra meydana gelen şüpheli eylemleri arayarak çevredeki olayları incelemek.
 4. Düşünceleri doğrulamak için tehdit istihbaratı platformlarını veya diğer mevcut kaynakları kullanmak.
- **Son Eylemler:** Bu aşamada verilen kararlar, potansiyel bir siber saldırının tespit edilip edilmediğini belirler. İncelenen uyarının kötü niyetli (**True Positive**) mi yoksa zararsız (**False Positive**) mi olduğuna karar verilir. Analiz adımlarını ve karar gerekçesini açıklayan ayrıntılı bir yorum hazırlanır ve uyarı **"Kapalı" (Closed)** durumuna getirilir.

2. Raporlama, Yükseltme ve İletişim

Bir uyarının analizi tamamlandıktan sonra, bulguların doğru bir şekilde belgelenmesi ve sonraki adımların belirlenmesi gerekir.

2.1. Uyarı Raporlaması

Bir uyarıyı kapatmadan veya L2'ye iletmeden önce raporlamak gerekebilir. Ekip standartlarına ve uyarının ciddiyetine bağlı olarak, kısa bir yorum yerine, ilgili tüm kanıtları içeren ayrıntılı bir inceleme dokümanı hazırlanması istenebilir. Bu, özellikle yükseltme gerektiren Gerçek Pozitifler için önemlidir.

Uyarı Raporu Amacı	Açıklama
Yükseltme için bağlam sağlama	- İyi yazılmış bir rapor, L2 analistleri için çok zaman kazandırır. - Ne olduğunu hızlıca anlamalarına yardımcı olur.
Bulguları kayıt altına alma	- Ham SIEM logları 3-12 ay saklanırken, uyarılar süresiz olarak tutulur. - Bu nedenle, tüm bağlamı uyarı içinde tutmak daha iyidir.

İnceleme becerilerini geliştirme	- "Basitçe açıklayamıyorsanız, yeterince iyi anlamamışsınız demektir." - Rapor yazmak, uyarıları özetleyerek L1 becerilerini artırmanın harika bir yoludur.
---	--

Rapor Formatı: Beş N Kuralı (Five Ws)

Bir rapor yazarken, L2 analisti veya bir BT uzmanı gibi raporu okuyacak kişinin bakış açısıyla düşünmek faydalıdır. **Beş N Kuralı** yaklaşımını takip ederek aşağıdaki unsurların rapora dahil edilmesi önerilir:

- **Kim (Who):** Hangi kullanıcı oturum açtı, komutu çalıştırdı veya dosyayı indirdi.
- **Ne (What):** Tam olarak hangi eylem veya olay dizisi gerçekleştirildi.
- **Ne Zaman (When):** Şüpheli etkinlik tam olarak ne zaman başladı ve bitti.
- **Nerede (Where):** Hangi cihaz, IP adresi veya web sitesi uyarıya dahil oldu.
- **Neden (Why):** En önemli "N"dir; nihai kararın gereğesidir.

2.2. Uyarı Yükseltme (Alert Escalation)

Eğer Gerçek Pozitif bir uyarı ek eylemler veya daha derin bir inceleme gerektiriyorsa, belirlenen prosedürlere göre L2 analistine yükseltilir. Bu noktada, hazırlanan uyarı raporu, L2 analistin ilk bağlamı hızla anlamasını ve sıfırdan analiz yapma süresini kısaltmasını sağlar.

Bir uyarının L2'ye yükseltilmesi gereken durumlar şunlardır:

1. Uyarı, daha derin bir inceleme veya DFIR (Dijital Adli Bilişim ve Olay Müdahalesi) gerektiren büyük bir siber saldırının göstergesidir.
2. Kötü amaçlı yazılım temizleme, ana bilgisayar izolasyonu veya parola sıfırlama gibi düzeltme eylemleri gereklidir.
3. Müşteriler, ortaklar, yönetim veya kolluk kuvvetleri ile iletişim kurulması gerekmektedir.
4. L1 analisti uyarıyı tam olarak anlamıyorsa ve daha kıdemli bir analistten yardım gerekiyorsa.

2.3. İletişim

Analiz sırasında veya sonrasında diğer departmanlarla iletişim kurmak gerekebilir. Örneğin, BT ekibine belirli kullanıcılara yönetici ayrıcalıkları verip vermediklerini sormak veya yeni işe alınan bir çalışan hakkında daha fazla bilgi almak için İK ile iletişime geçmek gerekebilir.

3. L1 Analistler için Destek Araçları

L1 analistlerinin incelemelerini verimli ve tutarlı bir şekilde yapmalarına yardımcı olmak için çeşitli kaynaklar mevcuttur.

3.1. SOC Çalışma Kitapları (Workbooks)

SOC Çalışma Kitabı (playbook veya runbook olarak da bilinir), belirli tehditleri verimli ve tutarlı bir şekilde araştırmak ve düzeltmek için gereken adımları tanımlayan yapılandırılmış bir belgedir. L1 analistleri daha genç uzmanlar olarak kabul edildiğinden, kıdemli analistler genellikle daha az deneyimli ekip üyelerini desteklemek için bu çalışma kitaplarını hazırlarlar. Hatalardan kaçınmak ve analizi standartlaştırmak için L1 analistlerinin uyarıları bu kitaplara göre incelemesi önerilir ve bazen zorunlu tutulur.

3.2. Envanterler

- **Kimlik Envanteri (Identity Inventory):** Kurumsal çalışanların (kullanıcı hesapları), hizmetlerin (makine hesapları) ve bunların ayrıcalıkları, iletişim bilgileri ve rolleri gibi ayrıntıların bir kataloğudur.
- **Varlık Envanteri (Asset Inventory):** Bir kuruluşun BT ortamındaki sunucular ve iş istasyonları gibi tüm bilgi işlem kaynaklarının bir listesidir.

4. SOC Performans Metrikleri ve Hedefleri

SOC ekibinin verimliliği, çeşitli göstergeler ve metrikler kullanılarak ölçülür. Bu metrikler, ekibin tehditleri tespit etme ve bunlara müdahale etme yeteneğini değerlendirmeye yardımcı olur.

4.1. Temel Performans Göstergeleri

- **Uyarı Sayısı (Alerts Count):** L1 analisti başına günde 5 ila 30 uyarı iyi bir metriktir. Çok yüksek bir sayı bunaltıcı olabilir ve gerçek tehditlerin gözden kaçmasına neden olabilirken, çok düşük bir sayı SIEM'de bir sorun veya görünürlük eksikliği olduğunu gösterebilir.
- **Yanlış Pozitif Oranı (False Positive Rate):** %0'lık bir oran ulaşılamaz bir idealdir, ancak %80 veya daha yüksek bir oran ciddi bir sorundur. Yüksek oranlar, analistlerin daha az dikkatli olmasına ve tehditleri "bir başka spam" olarak görmesine neden olabilir. Bu sorun genellikle araç ve tespit kurallarının ayarlanmasıyla ("Yanlış Pozitif Düzeltme") çözülür.
- **Uyarı Yükseltme Oranı (Alert Escalation Rate):** Bu oran genellikle %50'nin altında, hatta ideal olarak %20'nin altında hedeflenir. L1 analistlerinin ne kadar deneyimli ve bağımsız olduğunu ve ne sıklıkla bir uyarıyı yükseltmeye karar verdiklerini değerlendirir.
- **Tehdit Tespit Oranı (Threat Detection Rate - TDR):** Bu oran her zaman %100 olmalıdır. Gözden kaçan her tehdit, fidye yazılımı enfeksiyonu ve veri sızıntısı gibi yıkıcı sonuçlara yol açabilir.

4.2. Hizmet Seviyesi Anlaşması (SLA) Metrikleri

Bir uyarı tek başına bir ihlali durdurmaz; uyarıyı zamanında almak, önceliklendirmek ve saldırganlar hedeflerine ulaşmadan önce müdahale etmek önemlidir. Bu gereksinimler genellikle bir **Hizmet Seviyesi Anlaşması (SLA)** belgesinde gruplandırılır. SLA, tehditlerin hızlı bir şekilde tespit edilmesi, zamanında kabul edilmesi ve derhal müdahale edilmesini gerektirir.

- **MTTD (Ortalama Tespit Süresi - Mean Time To Detect):** Bir tehdidin tespit edilmesi için geçen ortalama süre.
- **MTTA (Ortalama Kabul Süresi - Mean Time To Acknowledge):** L1 analistlerinin bir uyarıyı incelemeye başlaması için geçen ortalama süre.
- **MTTR (Ortalama Müdahale Süresi - Mean Time To Response):** Bir cihazı izole etmek veya ihlal edilmiş bir hesabı güvence altına almak gibi bir tehdide müdahale etmek için geçen ortalama süre.